AegisBank 安全自评报告

自评日期：2026-11-01 | 本地模拟原型；不是生产认证或专业渗透测试结论。

仓库：https://github.com/0xChainAegis/aegisbank

1. 权限分级实现

等级	执行策略与代表操作
绿色	满足最小权限后自动执行余额、账单、交易等查询
黄色	展示当前对象 / 金额 / 风险并明确确认；包括日累计含本次 ≤1000 元的小额转账、取消订阅等
红色	明确确认并完成演示 OTP 或模拟生物识别；包括单笔 >5000 元、日累计 >1000 元转账、挂失 / 解挂、理财申购等

风险只能保持或上调。AuthzService 是能力校验的唯一口径；角色请求头不是认证。执行前重新评估风险、权限与 ActionEnvelope，撤权、过期、版本或哈希不一致均阻断。

2. 安全控制与验收依据

风险	当前控制	主要验证入口
幻觉与错误对象	确定性 Mock 事实、当前用户受控实体、候选白名单、歧义澄清	test_semantics、test_semantic_legacy、test_p0_core_feedback、test_u1_evaluation
Prompt 注入	指令与参数检查、整条任务拒绝、跨轮不继承权限	test_trust、test_nlp_safety
重放与重复扣款	nonce、有效期、计划 / 参数绑定、幂等键、草稿版本	test_trust、test_u2_lead_integration、test_u4_delivery_regression
未就绪与未知结果	readiness fail closed；UNKNOWN 不自动重试或展示成功	test_trust、test_compensation、前端 security.test.tsx
可疑行为	按用户熔断，合法只读保留；operator 解锁并写审计	test_breaker、test_breaker_business_effects、test_p0_core_feedback
非受控执行	ToolExecutor + SandboxGuard；网络、超时、体积、白名单检查	test_sandbox
补偿旁路	反向工具重走授权、风险、执行器与审计；不可逆明确拒绝	test_compensation、test_security_regressions
日志失真	SHA-256 链及 source / verified / verification_kind 证据分层	test_trust、六场景脚本、/api/audit/verify

逐项验证入口与当前实跑结果见《测试与复现》。测试文件名仅用于定位，不构成独立人工安全评审或第三方渗透结论。

3. 已知风险与生产化待办

1. 全部资金、账户和交易为 Mock Bank Core，不对接真实银行。

2. 无生产身份认证；客户端自报用户与角色只能用于本地演示，不形成真实身份隔离保证。

3. OTP 246810、模拟生物识别 token FACE-888888 为固定演示值，不是真实 MFA。

4. 沙箱在进程内运行；线程超时无法强杀线程，不是容器、命名空间或 OS 资源隔离。

5. IM / CLI / webhook 是适配协议，没有真实平台签名、租户和账号绑定。

6. SQLite 和本地哈希链不提供分布式一致性、高可用、WORM 或独立存证；有写库权限的人可能重算链。

7. 幂等键、已用 nonce 等仍需生产级过期 / 归档；有界草稿 TTL 与终态清理不代表全部表已解决增长问题。

8. 不支持任意自然语言、通用跨轮记忆或自由条件组合；离线评测不等同真实模型效果。

9. 自动测试和浏览器检查仅覆盖已知用例；独立人工手机 / 键盘 / 读屏验收、专业渗透与生产安全评审仍未完成。

10. 关怀模式只选择浏览器标记为本机的中文语音并按白名单读取业务摘要；实际设备听验和正式无障碍评估仍待完成。

4. 运行和数据边界

仅用虚构演示用户与独立模拟数据库。凭据置于本机忽略的配置文件，不进入源码、归档或材料。重置只针对明确指定的独立演示库，先停止服务，保留需要核对的审计证据。公开展示须说明模拟边界。